# A Comprehensive Vulnerability Assessment and Penetration Testing Procedure for Dark Web Sites

1st Ramya Madimi
*Center for Cybersecurity Systems and Networks*
*Amrita Vishwa Vidyapeetham*
Amritapuri, India
amenp2csn21011@am.students.amrita.edu

2nd Narayanan Subramanian
*Center for Cybersecurity Systems and Networks*
*Amrita Vishwa Vidyapeetham*
Amritapuri, India
nsubramanian@am.amrita.edu

***Abstract*—The Dark Web, a hidden part of the Internet, has become an important hub for various illegal activities such as drug dealing, weapon sales, terrorism, human trafficking, monetary fraud, etc. Given the nature of the dark web, it is challenging for security researchers and law enforcement agencies to track down these activities and apprehend the perpetrators. This project focuses on vulnerability assessment and penetration testing (VAPT) on dark web cybercrime websites, namely fake Bitcoins, drugs, weapons, terrorism, malware, hacking, and miscellaneous (a mixture of a few random cyber crimes) websites. We analyzed 163 dark websites, that are involved in illegal activities and evaluated the security posture using Wappalyzer, Open Worldwide Application (OWASP) Penetration Testing Kit, and Burp Suite tools. Out of the analyzed websites, our findings reveal that 147 dark websites are vulnerable to exploitation related to JavaScript libraries, WordPress, and the deprecation of critical security headers like X-Frame-Options, X-Content-Type-Options, and X-XSS-Protection. As part of penetration testing, 102 websites are exploited with Cookie Stealing, Session Hijacking, Password Reset Poisoning, Denial of Service (DoS), and Clickjacking attacks. We believe that our study can help law enforcement agencies (LEAs) and security researchers to better understand the vulnerabilities and weaknesses of dark websites, and develop effective strategies to combat illegal activities on the dark web.**

***Index Terms*—Dark Web, Vulnerability Assessment, Penetration Testing, Security Headers, Cookie Stealing, Clickjacking, Password Reset Poisoning, DoS**

## I. Introduction

The dark web is a section of the Internet that is not accessible by using search engines of the surface web. This anonymity has made the dark web an attractive platform for various illegal activities, including drug trafficking, weapon sales, terrorism, human trafficking, fraud, theft, hacking, etc. The rise of these activities has raised concerns for law enforcement agencies and security researchers who are tasked with tracking and investigating these activities. One of the main challenges in combating illegal activities on the dark web is the lack of visibility, making it difficult to identify and apprehend the perpetrators.

Dark websites have gained notoriety for facilitating various illicit activities, including the sale of drugs, weapons, stolen data, counterfeit goods, hacking tools, and other illegal goods and services [1], [8]. Due to the anonymity provided by the dark web, dark websites have become a significant challenge for law enforcement agencies and cybersecurity experts. Tracking the location, identity, and activities of individuals operating on the Dark web poses considerable difficulties, requiring specialized investigative techniques, tools, and collaborations between international LEAs.

In the past, research work focused on finding vulnerabilities on the surface web. Those included government and financial websites [3], [5]. Few studies performed vulnerability assessments specific to attack categories [4], [6]. Some researchers also worked on machine learning approaches for classifying malicious activities on the dark web [10], [11].

However, assessing the security posture of dark websites presents unique challenges due to the anonymity and hidden nature of the dark web [2]. Moreover, most dark websites are designed to be inaccessible to search engines, which makes automated vulnerability assessment tools ineffective. As a result, manual assessment techniques are required to identify vulnerabilities on dark websites.

In this paper, we present a vulnerability assessment and penetration testing procedure for dark websites using a comprehensive methodology that incorporates automated and manual techniques to identify and exploit security weaknesses. Our study aims to provide insights into the vulnerabilities and weaknesses of dark websites and to help law enforcement agencies and security researchers develop effective strategies to combat illegal activities on the dark web. We used Wappalyzer, OWASP Penetration Testing Kit, and Burp Suite tools to analyze 163 dark web cyber crimes, namely fake Bitcoins, drugs, weapons, terrorism, malware, hacking, and miscellaneous, websites. The security testing disclosed that 147 dark websites, out of the total analyzed websites, are vulnerable to JavaScript libraries, WordPress, and deprecated security headers like X-Content-Type-Options, X-Frame-Options, and X-XSS-Protection attacks. Also, we exploited 102 dark websites with Cookie Stealing, Session Hijacking, Password Reset Poisoning, DoS, and Clickjacking attacks.

## II. Related Work

The dark web, initially developed for legal purposes, is predominantly used for illegal purposes nowadays. Few research

studies provided an important context for understanding the need to assess and address security vulnerabilities on dark websites. Studies highlighted the diverse range of illegal activities occurring on the dark web and emphasize the importance of effective measures to combat these crimes [1].

The research papers, in the past, provided insights into the unique challenges of assessing vulnerabilities on the dark web and highlights the importance of proactive monitoring and assessment [2]. Some research work discussed the implications of the dark web for money laundering activities and presents counter strategies to combat these criminal activities [8], [9].

Few papers focused on web technologies used in governments and financial websites, based on the surface web [3], [5]. Some research studies have analyzed the prevalence and impact of attacks and vulnerabilities in various software and web development [4], and weaknesses that may result in operational disruptions or compromised security [6]. Studies also included methods to inspect non-intrusive detection methodologies which are useful in the identification of web application vulnerabilities [12]. Research had also explored web services attacks and security measures. It provided insights into common attack vectors and security concerns related to web services [7].

Although these studies do not focus on the dark web but provide valuable insights into common web vulnerabilities that could potentially exist on dark websites. The studies emphasize the need for vulnerability assessments to identify such weaknesses.

Few research studies highlighted the challenges associated with identifying malicious activities and presented a machine learning-based approach to classifying dark websites as either malicious or benign [10]. Some studies presented a framework for categorizing and classifying various types of illicit activities, including drug trafficking, hacking services, and counterfeit goods [11]. While it does not directly address vulnerability assessment, it provides an overview of the different illegal activities prevalent on the dark web, which can help inform vulnerability assessment efforts by identifying potential areas of risk and vulnerability.

## III. Methodology

In this project, VAPT is performed on 163 dark web cybercrime websites, containing categories: Weapons, Drugs, Terrorism, Fake BTC, Malware, Hacking, Misc, and the analyzed count of websites for each category is 42, 35, 15, 10, 12, 20, 29 respectively.

Fig. 1 explains the tools and techniques used to find vulnerabilities in the cybercrime websites of the dark web. First, dark websites' URLs are collected using manual scraping and 'Hunchly' reports. Then, the 'Wappalyzer' tool is used to fetch information about the vulnerable web technologies used by these websites. Once the technologies are listed, tools for finding vulnerabilities and techniques to exploit vulnerabilities are strategized. Vulnerabilities are found using the 'OWASP Penetration Testing Kit' tool and attacks are performed with the help of the 'Burp Suite' tool. Finally, the number of websites vulnerable to a particular exploit is recorded.

### A. Tools Setup Process

The procedure of installation and utilization of the tools, used in this project, is given below:

1) Hunchly Report – Hunchly is an OSINT tool that helps researchers and LEAs to know about the threat actors, track important forensic evidence, and preserve the evidence by documentation. Hunchly daily reports are a part of the Hunchly support feature, which provides the details about the dark websites which are 'Up', 'Down', and 'New' every day through registered email.
   For this project, the Hunchly daily reports were subscribed to through the Hunchly official website.
2) Wappalyzer – It is a tool used to provide information about the technologies used by a website.
   This tool is installed as an extension to the Firefox browser. Whenever a website is browsed, a single click on the shortcut button, appearing on the right side of the *Search* bar, provides the list of technologies used, placed in categories such CMS, JavaScript Libraries, Web Servers, etc.
3) OWASP Penetration Testing Kit – This tool provides useful information on the technology stack along with the version of each technology used, security headers, well-known vulnerabilities, each appearing with Common Vulnerabilities and Exposures (CVE) links alongside, etc.
   Here, in order to find vulnerabilities, this tool is installed as an extension to the Firefox browser. The shortcut of this extension appears on the right side of the *Search* bar. Upon clicking, it provides a report of web technologies used along with respective versions and CVE links, security headers, etc.
4) Burp Suite - This tool helps in security testing on web applications. It helps to build an attack scenario and execute exploits on websites to know the security posture.
   In this project, the Burp Suite Clickbandit, Intruder, and Repeater tools are used for performing clickjacking attacks, manual manipulation and replaying the requests, and automated attacks respectively.

### B. Vulnerability Assessment and Penetration Testing Procedure

This section shows the process followed to find vulnerabilities and perform penetration testing.

*1) Vulnerability Assessment Procedure:* The process used for finding vulnerabilities is explained below in brief:

- JavaScript Libraries, used in some websites, are found using the Wappalyzer tool.
- WordPress is used in some websites. It is found using the Wappalyzer tool.

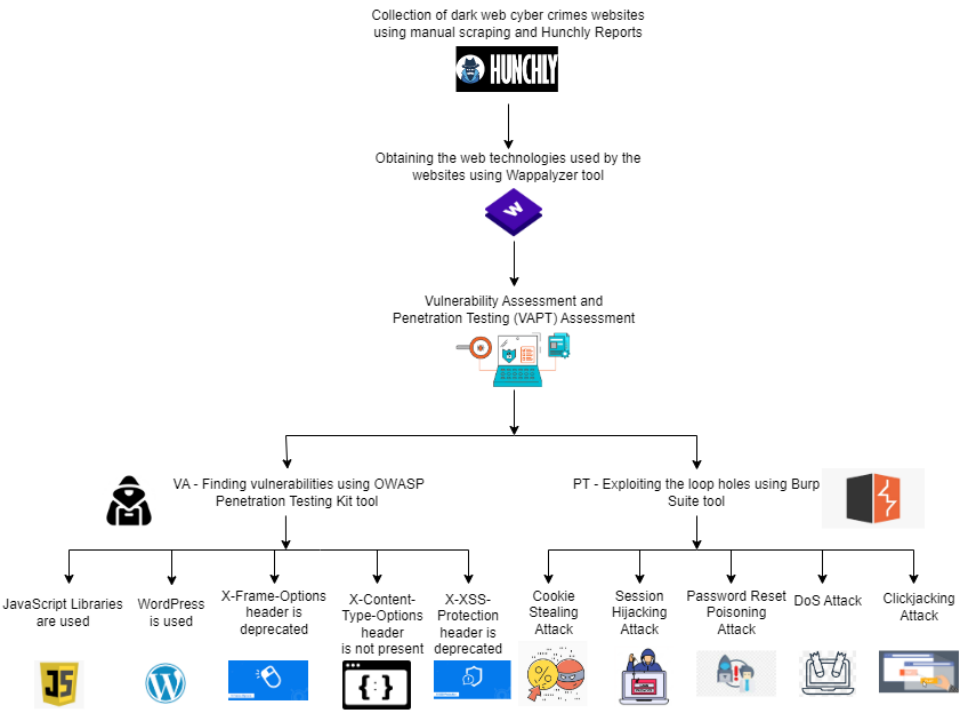



Fig. 1: Methodology Block Diagram

- X-Frame-Options header found deprecated in few websites. This is found using the OWASP Penetration Testing Kit tool.
- For some websites, X-Content-Type-Options header is not present. This vulnerability is found using the OWASP Penetration Testing Kit tool.
- X-XSS-Protection header found deprecated in few websites. This vulnerability is found using the OWASP Penetration Testing Kit tool.

*2) Penetration Testing Procedure:* Penetration testing is performed using the Burp Suite tool. The procedure followed to perform these attacks is explained below:-

- Cookie Stealing attack - This attack is performed by intercepting the request and fetching the cookie.
- Clickjacking Attack - Here, the Burp Suite *Clickbandit* code is copied using the *Copy to Clipboard* option and pasted in the *Console* dev tool of the website. After executing the code, the webpage appears with the *Start, Finish* options to perform the attack. Once the *Start* button is clicked, it provided the option to click on different buttons and links present on the website. Here, *Shop* link is clicked to find if it can be click jacked. After clicking on the button, *Finish* button is clicked.
- Session Hijacking attack - Here, *'We The North'* website is used for this attack and it is opened in two terminals, along with the Burp Suite tool. A user named *'north-hackergirl'* is logged into the website in the first terminal and the request is intercepted by the Burp Suite tool. The *Cookie* from the intercepted request is noted.In the second terminal, the login page of the website is intercepted by the tool and the *Cookie* again is noted and replaced with that of the first terminal to make the user logged in without actually entering the credentials.
- Password Reset Poisoning attack - In this attack, *'Genesis Drug Store'* marketplace is considered to have the user *'weiner'* logged in. Then the user is logged out and the request for the lost password is intercepted, after clicking on the *'Lost your password?'* link. The website asked for the *Username or email* to enter and the username *'weiner'* is entered. Then the password reset link is sent to the email address of the user. Upon clicking the link, a webpage asking to enter a new password appeared. After entering the new password, the request is again intercepted and sent to the *Repeater* tool of Burp Suite. Upon entering the new password, the user is logged in. Then the attack is performed by intercepting the request of a website, obtaining the cookie, and replacing the cookie of password reset of another user, in this case, *'carlos'* in the previously intercepted request of the genuine user.
- Denial of Service attack - This attack is performed by sending requests multiple times continuously and then measuring the increase in Central Processing Unit (CPU) and Memory usage percentages.

## IV. Results and Analysis

This section explains, in detail, the results obtained from the procedure explained in the methodology section.

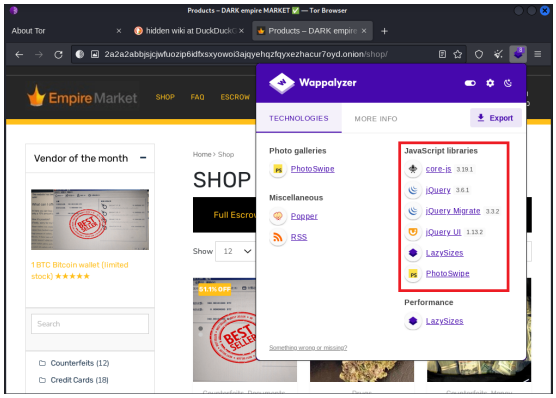



Fig. 2: JavaScript Libraries used in Empire Marketplace Website

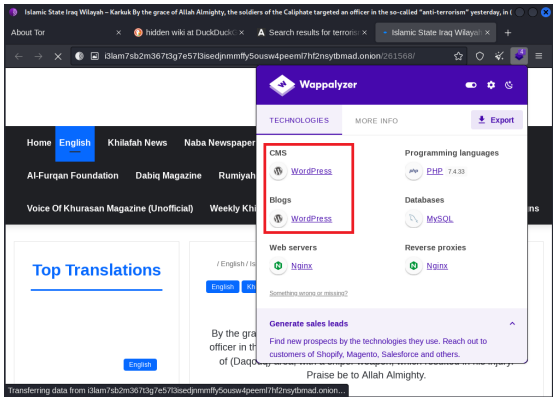



Fig. 3: WordPress used in Islamic State Iraq Wilayah Website

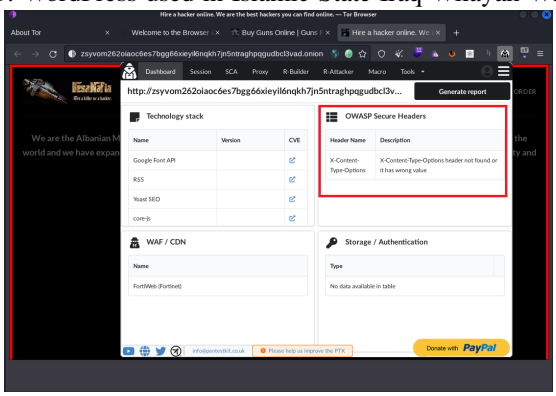



Fig. 4: Deprecated X-Frame-Option Header used in Besa Mafia WebsiteX-Content-Type-Options Header not found in Black Market Guns Website

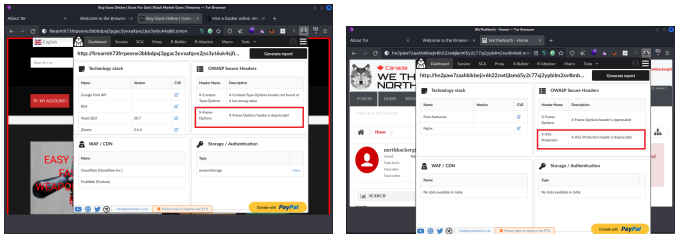
## V. Vulnerability Assessment Results

### A. JavaScript Libraries

Fig. 2 shows the screenshot of the list of JavaScript libraries detected by the Wappalyzer tool. The vulnerable web technology is detected on the *'Empire'* marketplace website as shown in the screenshot provided.

### B. WordPress

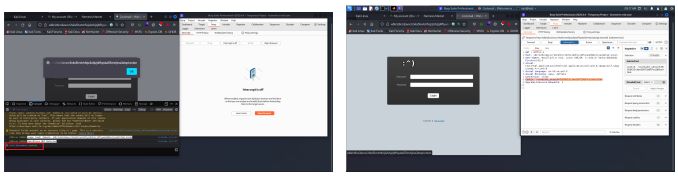
Fig. 3 shows the screenshot where vulnerable WordPress technology is detected by the Wappalyzer tool on the terrorism based *'Islamic State Iraq Wilayah'* website.



(a) Deprecated X-Frame-Option Header used in Besa Mafia Website

(b) Deprecated X-XSS-Protection Header not found in Black Market Guns Website

Fig. 5: Deprecated Security Headers



(a) Execution of 'alert(document.cookie)' in Console dev tool

(b) Fetching cookie by intercepting the request using Burp Suite tool

Fig. 6: Cookie Stealing Attack

### C. X-Content-Type-Options

Fig. 4 shows the screenshot of the OWASP Penetration Testing Kit report generated for finding vulnerabilities in *'Black Market Guns'* website. The screenshot shows that the X-Frame-Options header is not present on the website.

### D. X-Frame-Options

Fig. 5(a) shows the screenshot of the OWASP Penetration Testing Kit report generated for analyzing vulnerabilities in an assassination website named *'Besa Mafia*. The screenshot shows that the X-Frame-Options header is detected to be deprecated.

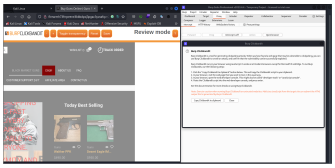
### E. X-XSS-Protection

Fig. 5(b) shows the screenshot of the OWASP Penetration Testing Kit report generated for analyzing *'We The North'* marketplace website. The screenshot shows that the X-XSS-Protection header is detected to be deprecated.

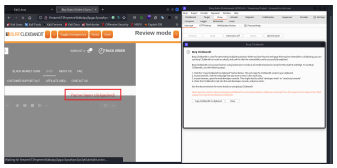
## VI. Penetration Testing Results

### A. Cookie Stealing Attack

The *'Cockmail'* website which is used for performing this attack. Fig. 6(a) shows that executing 'alert(document.cookie)' in the *Console* dev tool does not provide the cookie for the website. When the request is intercepted using the Burp Suite tool, the cookie can be seen as shown in Fig. 6(b).

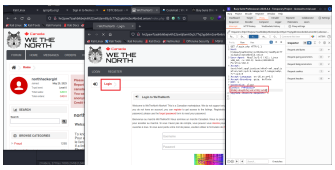


(a) Malicious Click option appears on SHOP link

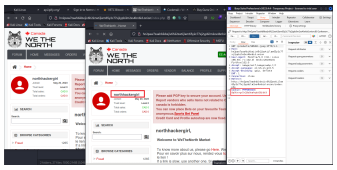


(b) Webpage showing 'You've been clikjacked after clicking the malicious link

Fig. 7: Clickjacking Attack



(a) Cookie in the second terminal replaced with that of first terminal



(b) User logged in the second terminal

Fig. 8: Session Hijacking Attack

### B. Clickjacking Attack

The *'Black Market Guns'* website is used for performing this attack. The webpage appears with a red colored *Click* button over the *Shop* link, after execution of the procedure mentioned in the methodology section, as shown in Fig. 7(a). Once the *Click* button is clicked, it shows *'You've been clickjacked'* as shown in Fig. 7(b).

### C. Session Hijacking Attack

In Fig. 8(a), after following the procedure explained in the methodology sect**??**the *Cookie* of the second terminal login webpage intercepted request is replaced with that of the first, and the request is forwarded. Fig. 8(b) shows that after forwarding the request having replaced with the first *Cookie*, the user gets automatically logged into the second terminal as well.

### D. Password Reset Poisoning Attack

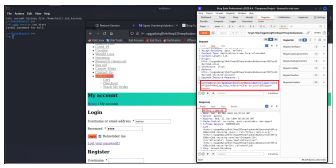
After following the procedure explained in the methodology section, Fig. 9(a) shows that when the password field is manipulated using the previously intercepted request and sent again using the *Repeater* tool, it gives a *'200 OK'*, i.e., success response.

Now the attack is performed by changing the username to that of a malicious user *'carlos'* in the request and sending it using the *Repeater* tool and it responds with a *'200 OK'*, i.e., success response as shown in Fig. 9(b).

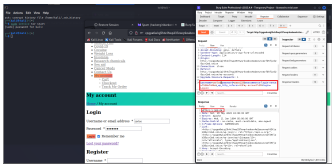
### E. DoS Attack

This attack is shown in terms of an increase in the *CPU* and *Memory* usage percentages. For this attack, the *'Black Market Guns'* website is used.

In Fig. 10(a), it can be seen that before the attack is performed, the *CPU* and *Memory* usage percentage values are *1* and *29* respectively. Fig. 10(b) shows that after continuously

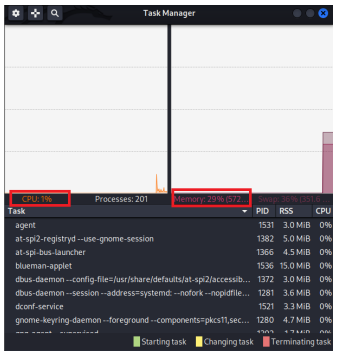


(a) Success response captured after changing the password again

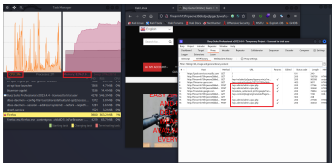


(b) Success response captured after changing the username to that of malicious user

Fig. 9: Password Reset Poisoning Attack




(a) CPU and Memory usage percentages before the attack



(b) CPU and Memory usage percentages after 4 continuous requests for Black Market Guns website

Fig. 10: Denial of Service (Dos) Attack

sending the request 4 times, which is logged in the *'HTTP History'* option of the Burp Suite tool, the *CPU* and *Memory* usage percentage values increased to *3* and *82* respectively.

### F. Statistical Results

In this project, out of 163 analyzed dark websites, 147 websites are found to have one or more vulnerabilities and 102 websites are exploited with one or more attacks listed further in this section. Table I shows the number of vulnerable and exploited dark websites category-wise. Table II shows the vulnerabilities detected and exploitation performed against the corresponding number of websites.

TABLE I: Category Wise Number of Vulnerable and Exploited Websites

| Category | Total Number of Websites | Number of Vulnerable Websites | Number of Exploited Websites |
|---|---|---|---|
| Weapons | 42 | 38 | 21 |
| Drugs | 35 | 33 | 18 |
| Terrorism | 15 | 12 | 11 |
| Fake BTC | 10 | 10 | 5 |
| Malware | 12 | 11 | 9 |
| Hacking | 20 | 19 | 19 |
| Misc | 29 | 24 | 19 |

TABLE II: Count of Websites for each Vulnerability and Attack

| Vulnerability | Number of Websites Vulnerable | Attack | Number of Websites Exploited |
|---|---|---|---|
| JavaScript Libraries are used | 88 | Cookie Stealing | 93 |
| WordPress is used | 69 | Clickjacking | 98 |
| X-Content-Type-Options header is not present | 73 | Session Hijacking | 89 |
| X-Frame-Options header is deprecated | 42 | Password Reset Poisoning | 34 |
| X-XSS-Protection header is deprecated | 26 | Denial of Service (DoS) | 56 |

## VII. Analysis of the Results

### A. Analysis of Vulnerability Assessment Results

1) Use of JavaScript Libraries - This vulnerability may lead to XSS attacks.
2) Use of WordPress - This vulnerability may lead to XSS attacks.
3) Deprecated X-Frame-Options header - Clickjacking exploitation may be performed due to this vulnerability.
4) Absence of X-Content-Type-Options header - This vulnerability may lead to XSS attacks.
5) Deprecated X-XSS-Protection header - This vulnerability may lead to XSS attacks.

### B. Analysis of Penetration Testing Results

1) Cookie Stealing attack - This attack may lead to an information breach. LEAs can fetch useful information about the dark web operators using the cookies, such as the passwords of the administrators.
2) Clickjacking attack - This attack is popularly known as *UI Redressing* attack. Using this attack, LEAs can manipulate the users of the websites to provide information about themselves by redirecting them to somewhere else.
3) Session Hijacking attack - This attack can prove very helpful for LEAs to track and monitor the activities of the users of dark websites indulged in cyber crimes.
4) Password Reset Poisoning attack - LEAs can either make a user non-functional or can impersonate to fetch information about the criminal activities happening in a dark website by performing this attack.
5) DoS attack - From the results, it can be seen that with a single system and a slight increase in the *CPU* usage percentage, the *Memory* usage percentage can be boosted to a very high level. This attack can be very helpful for LEAs to make a dark web cybercrime website unavailable for its users.

## VIII. Conclusion and Future Work

The dark web is a blooming hub for various illicit activities. Analyzing the security posture of the websites indulged in cyber crimes can be very useful for LEAs. We analyzed 163 websites belonging to the categories of namely fake Bitcoins, drugs, weapons, terrorism, malware, hacking, and miscellaneous. The insightful results obtained with the use of *Hunchly Report, Wappalyzer, OWASP Penetration Testing Kit,* and *Burp Suite* tools can help LEAs to track, monitor, and combat the cyber crimes operated through the dark web. The detected vulnerabilities due to the presence of web technologies like *JavaScript libraries, WordPress*, and deprecated security headers like *X-Frame-Options, X-Content-Type-Options, and X-XSS-Protection* can provide a means to exploit and gain information about the dark web operators and users. The *Cookie Stealing, Session Hijacking, Clickjacking, Password Reset Poisoning, and DoS* attacks performed as part of this project not only can help the LEAs to useful artifacts about the users, operators, and their operations but also can render the websites unavailable.

This VAPT project conducted on dark websites has provided valuable insights into the vulnerabilities and weaknesses present in these hidden corners of the internet. By combining vulnerability assessment and penetration testing techniques, this project can enable LEAs to understand the security risks associated with these hidden platforms and take proactive measures to mitigate them.

## References


[1] Kaur, S. and Randhawa, S., 2020. Dark web: A web of crimes. Wireless Personal Communications, 112, pp.2131-2158.

[2] Rawat, R., Rajawat, A.S., Mahor, V., Shaw, R.N. and Ghosh, A., 2021. Dark web—onion hidden service discovery and crawling for profiling morphing, unstructured crime and vulnerabilities prediction. In Innovations in Electrical and Electronic Engineering: Proceedings of ICEEE 2021 (pp. 717-734). Springer Singapore.

[3] Rakhmawati, N.A., Harits, S., Hermansyah, D. and Furqon, M.A., 2018. A survey of web technologies used in Indonesia local governments. Sisfo, 7(3), pp.213-222.

[4] Alvarez, D.E., Correa, D.B. and Arango, F.I., 2016, April. An analysis of XSS, CSRF and SQL injection in colombian software and web site development. In 2016 8th Euro American conference on telematics and information systems (EATIS) (pp. 1-5). IEEE.

[5] Masum, M.A., Sachcha, M.R.I. and Nayem, A., 2022. Security Analysis of Government & Financial Websites of Bangladesh.

[6] Using the Event Analysis of Systemic Teamwork (EAST) broken-links approach to understand vulnerabilities to disruption in a darknet market

[7] Mouli, V.R. and Jevitha, K.P., 2016. Web services attacks and security-a systematic literature review. Procedia Computer Science, 93, pp.870-877.

[8] Weber, J. and Kruisbergen, E.W., 2019. Criminal markets: the dark web, money laundering and counterstrategies-An overview of the 10th Research Conference on Organized Crime. Trends in Organized Crime, 22(3), pp.346-356.

[9] Zenebe, A., Shumba, M., Carillo, A. and Cuenca, S., 2019. Cyber threat discovery from dark web. EPiC Series in Computing, 64, pp.174-183.

[10] Kawaguchi, Y. and Ozawa, S., 2019. Exploring and identifying malicious sites in dark web using machine learning. In Neural Information Processing: 26th International Conference, ICONIP 2019, Sydney, NSW, Australia, December 12–15, 2019, Proceedings, Part III 26 (pp. 319-327). Springer International Publishing.

[11] He, S., He, Y. and Li, M., 2019, March. Classification of illegal activities on the dark web. In Proceedings of the 2nd International Conference on Information Science and Systems (pp. 73-78).

[12] Shaji, E. and Subramanian, N., 2021, July. Assessing Non-Intrusive Vulnerability Scanning Methodologies for Detecting Web Application Vulnerabilities on Large Scale. In 2021 International Conference on System, Computation, Automation and Networking (ICSCAN) (pp. 1-5). IEEE.